

Data Classification and Handling Policy

Versione: 1.0

Responsabile del documento: Chief Information Security Officer (CISO)

Approvata da: Board of Directors

Frequenza di revisione: Annuale

Data di efficacia: 19/08/2026

1. Purpose and Scope

La presente **Data Classification and Handling Policy** definisce i requisiti per la classificazione, il trattamento, l'accesso, la conservazione, la trasmissione e la distruzione delle informazioni gestite da **Finaxa**. L'obiettivo è garantire che i dati ricevano un livello di protezione proporzionato alla loro sensibilità, criticità e ai potenziali impatti derivanti da accesso, divulgazione, modifica, perdita o distruzione non autorizzati.

La policy si applica a dipendenti, collaboratori, contractor, consulenti, fornitori e altri soggetti autorizzati che trattano informazioni di Finaxa. Il perimetro comprende dati in formato digitale e fisico trattati attraverso sistemi on-premise, ambienti cloud, applicazioni SaaS, endpoint, database, sistemi finanziari e di pagamento e servizi forniti da terze parti.

2. Data Classification Levels

Le informazioni devono essere classificate dal **Data Owner** in base alla loro sensibilità, valore per il business, requisiti normativi e potenziale impatto derivante dalla loro compromissione.

2.1 Public

La **Multi-Factor Authentication (MFA)** deve essere applicata agli accessi remoti, agli account privilegiati, ai sistemi critici e agli ambienti che trattano dati di pagamento, inclusi i sistemi appartenenti al **Cardholder Data Environment (CDE)**.

2.2 Internal

Informazioni destinate all'utilizzo interno che non devono essere divulgate pubblicamente e che rappresentano informazioni riservate dell'organizzazione. La loro compromissione potrebbe avere un impatto significativo su operazioni,

processi o vantaggio competitivo di Finaxa, pur non raggiungendo il livello di criticità delle informazioni Confidential o Restricted.

Esempi: procedure operative interne, comunicazioni aziendali, documentazione organizzativa, materiale di formazione interno, linee guida tecniche e informazioni non pubbliche relative a processi e strutture aziendali.

2.3 Confidential

Informazioni sensibili la cui divulgazione, modifica o perdita non autorizzata potrebbe provocare danni finanziari, operativi, legali o reputazionali a Finaxa o ai suoi clienti.

Esempi: dati personali dei clienti e dei dipendenti, informazioni finanziarie, contratti, report di rischio, informazioni commerciali riservate e documentazione tecnica sensibile.

2.4 Restricted

Gli accessi privilegiati devono essere revisionati almeno **trimestralmente**, mentre gli accessi standard devono essere revisionati almeno **annualmente**. Le revisioni devono essere documentate e gli accessi non più necessari devono essere rimossi tempestivamente.

3. Policy statements

3.1 Classification and Ownership

Tutte le informazioni devono avere un **Data Owner** responsabile della classificazione e della verifica periodica del livello assegnato. La classificazione deve essere determinata considerando sensibilità, criticità, obblighi normativi e impatto potenziale sul business.

3.2 Access

Gli accessi concessi a fornitori e terze parti devono essere autorizzati, limitati al minimo necessario e, ove possibile, avere una scadenza definita. Gli accessi a sistemi critici devono essere protetti tramite MFA, sottoposti a logging e monitoraggio e revocati al termine dell'attività autorizzata.

3.3 Storage and Encryption

La conformità alla presente policy deve essere supportata da processi documentati di **Identity and Access Management (IAM)**. Ogni richiesta di accesso deve essere associata a una necessità aziendale, tracciata attraverso

un sistema autorizzato e approvata dal manager dell'utente o dal **System Owner** competente prima del provisioning.

3.3 Trasmission and Sharing

Il processo JML deve garantire che i nuovi utenti ricevano accessi coerenti con il proprio ruolo, che gli accessi vengano aggiornati in caso di trasferimento o modifica delle responsabilità e che quelli non più necessari siano tempestivamente revocati.

3.5 Data Minimization

I System Owner devono effettuare le access review secondo le frequenze stabilite e documentarne l'esito. I log relativi agli accessi privilegiati, remoti e ai sistemi critici devono essere monitorati per identificare attività anomale o non autorizzate. Le evidenze relative a richieste, approvazioni, revisioni e revoche devono essere conservate secondo i requisiti aziendali di audit e compliance.

3.6 Retention

Le informazioni devono essere conservate esclusivamente per il periodo necessario a soddisfare requisiti operativi, legali, regolamentari e contrattuali. I periodi di conservazione devono essere definiti nel **Data Retention Schedule** e applicati in funzione della tipologia di informazione.

3.7 Secure Disposal

Alla scadenza del periodo di conservazione, le informazioni devono essere eliminate o distrutte attraverso metodi appropriati al supporto e al livello di classificazione, in modo da impedirne il recupero non autorizzato.

3.8 Data Handling Incidents

La perdita, divulgazione, trasmissione o accesso non autorizzato a informazioni Confidential o Restricted deve essere segnalato tempestivamente e gestito secondo la **Incident Response Policy**.

4. Procedures

I Data Owner devono assegnare il livello di classificazione appropriato alle informazioni di propria competenza e riesaminarlo quando cambiano sensibilità, utilizzo, requisiti normativi o finalità del trattamento.

I sistemi e i repository utilizzati per archiviare informazioni Confidential o Restricted devono applicare controlli coerenti con la classificazione assegnata, inclusi access control, encryption, logging, backup e monitoraggio quando appropriato.

La condivisione di dati sensibili con soggetti esterni deve essere autorizzata e limitata alle informazioni necessarie. Prima della condivisione devono essere verificati i requisiti di sicurezza e gli obblighi contrattuali applicabili alla terza parte.

La conservazione e la distruzione delle informazioni devono essere gestite secondo il Data Retention Schedule e le procedure aziendali approvate. Le attività rilevanti devono produrre evidenze adeguate alle esigenze di audit e compliance.

5. Roles and Responsibilities

I **CISO** è owner della presente policy e supervisiona i requisiti di sicurezza applicabili alla protezione delle informazioni.

I **Data Owner** sono responsabili della classificazione delle informazioni, dell'approvazione degli accessi e della verifica periodica della classificazione assegnata.

L'**IT Security Team** definisce e monitora i controlli tecnici necessari a proteggere i dati in funzione della loro classificazione.

La funzione **IT** implementa e mantiene i controlli tecnici relativi a storage, encryption, backup, access control e secure disposal.

Le funzioni **Privacy, Legal e Compliance** supportano l'identificazione dei requisiti legali, regolamentari e contrattuali applicabili al trattamento e alla conservazione delle informazioni.

Tutti gli **utenti** devono trattare le informazioni secondo il livello di classificazione assegnato e segnalare tempestivamente eventuali perdite, divulgazioni o accessi non autorizzati.

Le **terze parti** che trattano informazioni di Finaxa devono rispettare i requisiti di sicurezza, privacy e data handling stabiliti nei relativi accordi contrattuali.

6. Exceptions Process

Qualsiasi eccezione alla presente policy deve essere documentata e giustificata da una necessità aziendale. La richiesta deve identificare i dati interessati, il requisito non rispettato, il rischio associato, la durata dell'eccezione e gli eventuali **compensating controls**.

Le eccezioni devono essere sottoposte a valutazione del rischio e approvate dal CISO o dall'autorità designata. Le eccezioni che comportano un rischio elevato o critico devono essere sottoposte al Risk Management e, quando necessario, al senior management per l'accettazione formale del rischio. Ogni eccezione deve avere una scadenza definita ed essere sottoposta a revisione.

7. Review Cycle

Il rispetto della presente policy è obbligatorio per tutti i soggetti che trattano informazioni di Finaxa. La classificazione e il trattamento dei dati devono essere gestiti in coerenza con i requisiti normativi, contrattuali e di sicurezza applicabili all'organizzazione, inclusi **GDPR, UK GDPR, PCI DSS e DORA**.

La mancata conformità può comportare limitazione o revoca degli accessi, azioni disciplinari, investigazioni interne, escalation al management o azioni contrattuali nei confronti delle terze parti. Eventi che comportano perdita, accesso o divulgazione non autorizzata di dati devono essere valutati secondo la **Incident Response Policy** e gli eventuali obblighi di data breach notification applicabili.

8. Review and Maintenance

La presente policy deve essere revisionata almeno **annualmente** sotto la responsabilità del CISO. Una revisione straordinaria deve essere effettuata in seguito a modifiche normative, incidenti significativi, audit finding rilevanti o cambiamenti sostanziali nelle tipologie di dati, nei sistemi utilizzati o nel profilo di rischio di Finaxa.

Ogni aggiornamento deve essere documentato tramite controllo di versione e le modifiche rilevanti devono essere comunicate agli stakeholder interessati.

9. Related Documents

La presente **Data Classification and Handling Policy** è subordinata alla **Information Security Policy** di Finaxa e deve essere applicata congiuntamente, ove pertinente, alla **Access Control Policy**, **Incident Response Policy**, **Third-Party Risk Management Policy**, **Acceptable Use Policy** e alle procedure aziendali di **Data Retention and Secure Disposal**.